Security Control Mapping Assessment

PREMIER UNIVERSITY | SIMULATED ACADEMIC CASE STUDY

Framework: NIST SP 800-53 Revision 5 • Prepared for a GRC portfolio • October 2026

Executive Summary

Premier University is a fictional institution serving approximately 15,000 students and 2,000 faculty and staff. The academic scenario identifies four security concerns: excessive access to student records, missing software updates, inconsistent security log review, and untested restoration procedures. This report maps each concern to a relevant NIST SP 800-53 Rev. 5 control and proposes practical mitigation and verification approaches. The recommendations have not been implemented or tested as part of this exercise.

Assessment Scope and Method

Scope covers the four risks specified in the scenario, with emphasis on security requirements, control selection, and suggested implementation measures. The approach was to (1) identify the underlying requirement, (2) select a primary NIST control, (3) explain the risk-to-control relationship, and (4) identify possible implementation activities and future audit evidence. No actual university systems, documents, or personnel were examined.

Control Mapping Summary

Risk	Primary control	Recommended response
Unauthorized Access	AC-6 — Least Privilege	Implement role-based permissions and quarterly access reviews.
Missing Security Updates	SI-2 — Flaw Remediation	Deploy approved patches via centralized patch management; track exceptions.
Inadequate Audit Logging	AU-6 — Audit Record Review, Analysis, and Reporting	Centralize logs in a SIEM and define alert triage and review procedures.
Weak Backup Procedures	CP-4 — Contingency Plan Testing	Run quarterly restoration exercises; record results and corrective actions.

Risk Findings and Recommended Safeguards

R-001 | Unauthorized Access — AC-6 Least Privilege

Scenario observation: Employees have excessive access to sensitive student records.

Security requirement: Restrict access to authorized job duties.

Control rationale: Minimum necessary permissions reduce unauthorized disclosure and misuse.

Implementation: Implement role-based permissions and quarterly access reviews.

Potential audit evidence: Role-permission matrix; access review approvals; user entitlement export.

R-002 | Missing Security Updates — SI-2 Flaw Remediation

Scenario observation: Computers and servers run outdated software with known vulnerabilities.

Security requirement: Identify and remediate software flaws in a timely manner.

Control rationale: Timely flaw remediation reduces exploitation of known vulnerabilities.

Implementation: Deploy approved patches via centralized patch management; track exceptions.

Potential audit evidence: Patch compliance reports; remediation tickets; vulnerability scans.

R-003 | Inadequate Audit Logging — AU-6 Audit Record Review, Analysis, and Reporting

Scenario observation: Security logs are not consistently collected or reviewed.

Security requirement: Review security events and investigate suspicious activity.

Control rationale: Reviewing and analyzing records supports detection and investigation of unusual activity.

Implementation: Centralize logs in a SIEM and define alert triage and review procedures.

Potential audit evidence: SIEM review logs; alert tickets; documented log review procedures.

R-004 | Weak Backup Procedures — CP-4 Contingency Plan Testing

Scenario observation: Backups occur but restoration is not regularly tested.

Security requirement: Validate recoverability of critical systems and information.

Control rationale: Testing recovery procedures identifies restoration weaknesses before a disruptive incident.

Implementation: Run quarterly restoration exercises; record results and corrective actions.

Potential audit evidence: Recovery test results; exercise reports; remediation records.

Considerations for IT Audit and GRC

Control mapping identifies a relevant safeguard, but does not establish whether it is implemented or effective. An auditor would need to obtain documentation, define test criteria, sample relevant activity, and evaluate evidence before reaching a conclusion. AU-12 (Audit Record Generation) may complement AU-6 when log collection is incomplete; CP-9 (System Backup) may complement CP-4 when evaluating backup procedures.

Management Recommendations

Prioritize validation of student-record entitlements, establish a documented patch remediation cadence, define responsibility for security log review, and schedule restoration exercises with documented outcomes. Assign accountable owners and target dates before treating these recommendations as an actionable remediation plan. Risk ratings and implementation status remain unassessed because the scenario does not provide sufficient supporting evidence.

Limitations and Reference

This is a simulated academic control-mapping exercise, not an audit opinion or an evaluation of a real university. No control testing was conducted. Reference: NIST SP 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations, https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final